MESSAF

Note de sécurité

Équipe	Challengers	Établissement	Institut Supérieur de Génie Électrique du Burkina Faso
Rédaction	SANOU Tolo Thède Axel	Dépôt public	github.com/nouxel00/messaf

Le serveur de MESSAF ne lit aucun message : le contenu est chiffré de bout en bout sur les appareils, l'accès exige un compte enrôlé avec second facteur, et un agent révoqué perd ses sessions en deux minutes au plus. Le serveur voit en revanche des métadonnées, détaillées plus bas, et le prototype a des limites connues.

1. Périmètre et modèle de confiance

Ce qui est protégé : le contenu des messages, fichiers et vocaux ; l'identité des agents ; l'accès aux salons de fonction.

Qui voit quoi :

- **Les appareils des agents** détiennent les clés et voient le contenu. Le chiffrement suit le protocole Matrix (Olm entre appareils, Megolm pour les salons), par la bibliothèque vodozemac de matrix-rust-sdk. Aucune cryptographie n'est développée par l'équipe.
- **Le serveur** (Synapse, sa base et son administrateur) ne reçoit que du chiffré. Il n'est pas digne de confiance pour le contenu, mais il l'est pour acheminer les messages et garder les métadonnées.
- **L'identité** est tenue par Keycloak, qui impose le second facteur. MAS (Matrix Authentication Service) ouvre les sessions des applications ; ni Synapse ni le portail ne voient un mot de passe.
- **Le bot de fonction** est membre des salons de fonction pour transmettre leur historique au successeur. Il détient donc leurs clés : c'est un composant de confiance, isolé dans son conteneur.

2. Menaces prises en compte et protections

La colonne Vérification renvoie aux tests automatisés du dépôt (`tests/`) ou à l'épreuve que le jury peut refaire.

Menace	Protection	Vérification
Lecture des messages par le serveur ou son administrateur	Chiffrement de bout en bout sur l'appareil ; Synapse ne stocke que des `m.room.encrypted` ; tous les salons sont chiffrés	Tests « serveur aveugle » : aucun message en clair en base
Interception du trafic	Contenu déjà chiffré avant l'envoi ; fédération fermée, aucun serveur extérieur contacté (pas de serveur de clés, pas de statistiques, pas d'aperçu de liens)	Inspection du trafic
Vol de mot de passe, usurpation	Mot de passe personnel, code TOTP et codes de secours imposés ; activation par un code à usage unique remis en main propre ; connexion par mot de passe refusée par Synapse	Test « intrus »
Compte non enrôlé	Inscription fermée dans Synapse, MAS et Keycloak ; seuls les identifiants `m` + matricule sont acceptés ; salons sur invitation seulement	Tests « intrus » : inscription, fédération, jeton inconnu, salon de fonction
Téléphone perdu ou volé	Révocation : compte bloqué dans Keycloak et MAS, toutes les sessions fermées ; l'agent peut aussi fermer ses sessions depuis un autre appareil ; code PIN obligatoire, trois erreurs déconnectent	Test « révocation » : délai mesuré
Agent muté qui garde l'accès	Passation : le sortant est retiré des salons de la fonction, et les clés sont renouvelées au message suivant ; l'intérimaire n'a pas l'historique et sort à la fin de l'intérim	Démonstration de passation
Fuite par capture d'écran ou transfert	Salons classés : seuls les agents habilités y entrent, captures d'écran bloquées, transfert et copie retirés	Démonstration
Abus de droits d'administration	Rôles cloisonnés par ministère et vérifiés par l'API à chaque appel ; le portail ne lit aucun message ; journal d'audit en ajout seul, refus compris	Journal d'audit
Service interne attaqué	API du bot joignable seulement dans le réseau Docker, protégée par un secret partagé ; secrets générés au premier démarrage, jamais dans Git ; jeton et magasin de clés du bot lisibles par lui seul	Configuration (`docker-compose.yml`)

3. Métadonnées visibles par le serveur

Le serveur ne lit pas le contenu, mais il sait qui échange avec qui et quand. Il voit :

- les membres de chaque salon, les invitations et les départs ;
- l'heure et la taille de chaque message et de chaque fichier, sans leur contenu ;
- les appareils de chaque agent et les adresses IP de connexion ;
- l'état des salons, qui n'est pas chiffré dans Matrix : nom (par exemple FCT-DRH-SANTE · DH-SANTE), sujet, droits, et l'état `bf.messaf.salon` (fonctions, titulaires, intérimaires, niveau de classification) ;
- les accusés de lecture et les indicateurs de saisie ;
- l'annuaire des agents (nom affiché, identifiant), consultable par tout agent enrôlé.

Ce qui les réduit : fédération fermée, ces métadonnées ne quittent pas le serveur de l'État ; présence désactivée (ni « en ligne » ni « vu à ») ; aucun aperçu de lien calculé par le serveur ; noms de salons neutres, formés de codes de poste ; aucun appel à un service extérieur.

4. Limites connues

- **Prototype local** : HTTP sans TLS sur `localhost`, Keycloak en mode développement, un seul serveur. En production : TLS partout, Keycloak en mode production, clés du serveur dans un module matériel.
- **Bot de fonction** : il détient les clés des salons de fonction. S'il était compromis, ces salons seraient lisibles. Il n'a aucun port publié et son magasin de clés est chiffré ; en production, il tournerait sur une machine distincte.
- **Historique transmis** : seulement aux appareils vérifiés (signature croisée) que le successeur possède au moment de l'invitation.
- **Délai de révocation** : Synapse garde la validité d'un jeton en mémoire jusqu'à deux minutes ; le test automatisé mesure le délai réel.
- **Classification** : le niveau est fixé par salon et visible du serveur ; les notifications et la visionneuse de médias ne sont pas encore restreintes. Une photo de l'écran prise avec un autre téléphone reste impossible à empêcher.
- **Journal d'audit** : un administrateur de la base de données peut retirer les déclencheurs qui le protègent ; en production, l'API n'aurait que les droits d'ajout et de lecture sur cette table.
- **Appareil compromis** : un logiciel malveillant installé sur le téléphone de l'agent, notamment un faux service d'accessibilité, voit ce que voit l'agent ; c'est hors de portée d'une messagerie.
- **Métadonnées** : celles qui sont listées plus haut restent visibles par l'administrateur du serveur.